

KASBAH – CELLULE DE CRISE ATLASGRID – J3

PLAN DE CONTAINMENT (ENDIGUEMENT) ET DE CONTINUITÉ D'ACTIVITÉ

Pôle pilote : Continuité d'activité · Incident : MIRAGE

Objectif. Contenir la propagation de MIRAGE, couper les accès et communications à risque, préserver les systèmes industriels, maintenir les fonctions métier essentielles et préparer une reprise progressive à partir d'une source de sauvegarde validée.

1. Actifs critiques et priorités de protection

Actif / service	Criticité	Rôle métier	Situation
OT / SCADA-HMI	Vitale	Production et distribution ; continuité des opérations industrielles.	Isolé et intact ; surveillance renforcée.
Active Directory	Critique	Authentification, gestion des identités et accès nécessaires à la reconstruction du SI.	DC-01 dégradé ; priorité de reprise.
ERP / Base de données	Critique	Socle des processus de gestion, dont dépendent notamment la paie et la facturation.	Services touchés / indisponibles.
Paie / Facturation	Critique	Paie des collaborateurs, facturation client et continuité financière.	Services touchés / indisponibles.
Partages de fichiers	Élevée	Documents opérationnels et données partagées.	Partages chiffrés par MIRAGE.
LTO-9 Settati	Critique – Reprise	Source de sauvegarde hors ligne indépendante du réseau compromis.	Copie J-42, isolée, jamais testée ; intégrité à valider.

2. Impact métier consolidé

Processus	Impact constaté	Criticité	Continuité recherchée
Production OT	Aucune compromission établie ; risque de propagation à prévenir.	Vitale	Maintien en exploitation sous surveillance.
ERP / Gestion	Interruption des fonctions de gestion et dépendances métier.	Critique	Restauration prioritaire après AD.
Paie	Chaîne de paie indisponible.	Critique	Mode dégradé financier puis restauration.
Facturation	Facturation client perturbée avec impact sur les flux financiers.	Critique	Mode dégradé puis restauration.
Fichiers	Partages chiffrés et indisponibles.	Élevée	Restauration après les services prioritaires.
Messagerie	Communications internes et externes dégradées.	Moyenne	Maintien des canaux disponibles et procédures alternatives.

3. Plan d'endiguement et de continuité

Type	Action	Responsable	Délai	Résultat attendu
Isolation	Isoler FIN-112 sous tension afin de stopper ses communications tout en préservant les traces nécessaires à l'investigation.	SOC / RSSI	Immédiat	FIN-112 ne communique plus avec le SI ni l'extérieur.
Isolation	Isoler les segments IT critiques touchés sans interrompre le réseau OT/SCADA.	Réseau / RSSI	Immédiat	Propagation latérale limitée ; OT préservé.
Coupure	Suspendre les sessions et accès VPN associés à <code>svc_oasisnet</code> et aux accès prestataire concernés.	RSSI / DSI	Immédiat	Aucune nouvelle connexion via les accès suspendus.
Coupure	Désactiver la règle OUT-TEMP-443 et bloquer les communications vers 45.137.184.62:443.	Réseau / SOC	Immédiat	Canal sortant identifié neutralisé.
Protection	Maintenir OT/SCADA isolé sous surveillance renforcée, avec critères prédéfinis de coupure d'urgence.	OT / RSSI	Continu	Aucune communication non autorisée vers l'OT.
Sauvegarde	Écarter RP-J-1 et RP-J-0 des sources de restauration.	DSI / PRA	Immédiat	Aucune restauration depuis un point suspect ou infecté.
Validation	Tester l'intégrité de la copie LTO-9 de Settat dans un environnement isolé avant toute restauration en production.	DSI / Continuité	Avant reprise	Source de restauration validée et documentée.
Bascule	Activer les procédures métier dégradées pour les fonctions financières essentielles pendant l'indisponibilité des systèmes.	Finance / Continuité	< 24 h	Paie et opérations financières prioritaires maintenues.
Reprise	Restaurer progressivement : AD → ERP / DB → paie / facturation → partages de fichiers.	DSI / Continuité	5–10 jours	Services critiques remis en fonctionnement par priorité.
Réouverture	Reconnecter les services par paliers après validation de sécurité et de stabilité à chaque étape.	DSI / RSSI	Après validation	Aucun service réouvert sans contrôle préalable.

4. Critères de maintien, coupure et bascule

Périmètre	Critère de décision	Action associée
OT / SCADA	Aucune compromission ou session non autorisée établie.	Maintenir l'exploitation avec surveillance renforcée.
OT / SCADA	Détection d'une session, d'un flux ou d'un comportement non autorisé franchissant la frontière IT/OT.	Déclencher la procédure de coupure d'urgence prévue.
Services IT	Présence d'activité MIRAGE ou d'indicateurs associés.	Isoler immédiatement l'actif ou le segment concerné.
Sauvegardes	Point de restauration suspect, infecté ou dont l'intégrité n'est pas démontrée.	Interdire son utilisation pour la reprise.
LTO-9 Settatt	Intégrité et absence d'indicateurs MIRAGE validées en environnement isolé.	Autoriser la restauration progressive.
Services restaurés	Tests fonctionnels et contrôles de sécurité concluants.	Autoriser la reconnexion progressive au SI.

5. Séquence de reprise retenue

Validation LTO-9 → AD → ERP / Base → Paie / Facturation → Partages de fichiers → Réouverture progressive

La copie LTO-9 de Settatt date de J-42 et n'a jamais été testée. Elle constitue une source indépendante du réseau compromis, mais **aucune restauration ne doit commencer avant validation de son intégrité**.

Les points Veeam RP-J-1 et RP-J-0 sont exclus : RP-J-1 est suspect et RP-J-0 est infecté par MIRAGE.

6. Points de contrôle avant réouverture

- Aucun indicateur MIRAGE détecté sur le système restauré.
- Comptes privilégiés et accès prestataires contrôlés avant reconnexion.
- Flux entrants et sortants vérifiés et journalisés.
- Protection endpoint / EDR active avant remise en service.
- Test fonctionnel réalisé par le responsable métier.
- Validation conjointe DSI / RSSI avant reconnexion au réseau de production.

7. Synthèse de la stratégie

Stopper	Isoler FIN-112 et les segments touchés, suspendre les accès prestataires concernés et neutraliser le canal sortant identifié.
Protéger	Maintenir l'OT/SCADA isolé sous surveillance et préserver la copie hors ligne de Settatt.
Continuer	Activer les modes dégradés pour les fonctions métier essentielles.
Restaurer	Valider la LTO-9 puis reconstruire selon l'ordre AD → ERP/DB → paie/facturation → fichiers.
Réouvrir	Reconnecter progressivement chaque service uniquement après validation technique, sécurité et métier.

Principe de décision : l'endiguement est ciblé afin de limiter la propagation sans provoquer un arrêt général injustifié. Toute restauration ou reconnexion est conditionnée par une validation préalable de l'intégrité, de la sécurité et du fonctionnement du service concerné.